

Výstupy ŠVP

INF-19a Chráním digitální zařízení a digitální obsah před poškozením či zneužitím s vědomím změn v technologiích, které ovlivňují bezpečnost. (Informatika 4, 2/2 · z INF-19)

Učivo: bezpečnost počítačových zařízení a dat

Připomenutí

$$N = k^n$$

$$b = \log_2 N = n \log_2 k$$

$$N = s^m$$

$$t = \frac{N}{v}$$

Bezpečnost zařízení a dat: typy útoků a sociotechnika, síla hesla jako kombinatorika, správce hesel, vícefaktorové ověření, aktualizace, antivir a zálohování. Při práci na vlastním zařízení nikdy nikomu neukazuj ani nezapisuj svá hesla. Podrobnosti najdeš v listu Must know.

A. Rozcvička

- Přiřaď pojmy virus, červ, trojský kůň, ransomware, spyware, phishing, vishing, credential stuffing k popisům: a) „zdarma stažená hra“ po instalaci otevře útočníkovi přístup; b) zašifruje fotky a chce platbu v kryptoměně; c) SMS s odkazem na „doplatek za zásilku“ vede na falešnou platební bránu; d) telefonát „z banky“ žádá kód z SMS; e) šíří se sám po síti přes neaktualizované počítače; f) uniklé heslo z e-shopu útočník zkouší na e-mailu; g) připojí se k programu a šíří se s ním; h) tajně posílá, co píšeš na klávesnici. ★☆☆
- Kolik je všech možných: 4místných PINů; 6místných PINů; hesel ze 6 malých písmen anglické abecedy; hesel ze 6 znaků, kde znak je malé písmeno nebo číslice? ★☆☆
- U každého způsobu ověření urči, zda jde o „něco znám“, „něco mám“, nebo „něco jsem“: heslo, PIN, otisk prstu, kód z ověřovací aplikace v telefonu, bezpečnostní klíč USB, odpověď na kontrolní otázku, rozpoznání obličeje. Je přihlášení heslem a kontrolní otázkou dvoufaktorové? ★☆☆
- Najdi aspoň pět varovných znaků ve zprávě (banka i adresa jsou smyšlené): „Vážený kliente, z důvodu podezřelé aktivity bude Váš účet do 24 hodin zablokován. Pro ověření klikněte na <https://prikладova-banka.cz/overeni-uctu.example/login> a zadejte přihlašovací jméno, heslo a kód z SMS. Banka Příkladová“ ★☆☆
- Eva má fotky jen v telefonu a kopii na flashce, kterou nosí v pouzdře u telefonu. Splňuje pravidlo 3-2-1? Co jí doporučíš? ★☆☆
- Které heslo je silnější: „Tr0ub4dor&3“ (11 znaků z 95), nebo čtyři náhodně vylosovaná slova ze seznamu 7 776 slov, např. „kolo slon hrnek modra“? Spočítej počet možností u obou a vysvětli, proč výpočet u prvního hesla přeceňuje jeho sílu. ★☆☆
- Proč útočníci nejvíc útočí v dnech a týdnech po vydání bezpečnostní aktualizace? Co je zranitelnost nultého dne? ★☆☆
- Co program vypíše? Vysvětli, co znamenají obě čísla ve výsledku. ★☆☆

```
import math
def sila(k, n):
    N = k ** n
    return N, round(math.log2(N), 1)

print(sila(10, 4))
print(sila(26, 8))
print(sila(95, 12))
```

B. Slovní úlohy

- Útočník zkouší 10^{10} hesel za sekundu (uniklá databáze). Jak dlouho mu nejdéle trvá prolomit náhodné heslo: 8 malých písmen; 8 znaků z 62; 12 znaků z 62; 16 malých písmen? Výpočty ověř funkcí sila z úlohy 8. ★☆☆
- Web po 5 chybných pokusech zablokuje přihlášení na 15 minut, útočník tedy stihne nejvýš 20 pokusů za hodinu. Jak dlouho by online zkoušel všechny 4místné PINy? A kdyby měl uniklou databázi a zkoušel offline 10^{10} pokusů/s? Co z toho plyne pro opakované používání hesel? ★☆☆

11. Kolik náhodně vylosovaných slov ze seznamu 7 776 slov potřebuješ, aby frázové heslo mělo aspoň tolik možností jako náhodné heslo z 12 znaků z 95 ($5,4 \cdot 10^{23}$)? Kolik bitů přidá jedno slovo? Jak by to vyšlo se slovníkem 50 000 českých slov? ★★☆☆
12. Zloděj má na uhodnutí 4místného PINu platební karty 3 pokusy, pak se karta zablokuje. Jaká je pravděpodobnost úspěchu, je-li PIN náhodný? Proč je skutečná šance často vyšší? ★☆☆
13. Útočník zná tvé heslo z úniku, ale máš zapnuté dvoufaktorové ověření aplikací v telefonu. Proč se do účtu nedostane? Popiš tři způsoby, jak se ho může pokusit obejít, a obranu proti nim. Který druhý faktor odolá i falešné přihlašovací stránce? ★★☆☆
14. Během online lekce ti na Discordu napíše neznámý účet: „Dobrý den, tady IT oddělení školy, děláme údržbu systému. Potřebuji hned tvoje heslo do školního účtu, jinak se ti smaže celé portfolio.“ Které sociotechnické triky používá a jak správně reagovat? ★☆☆
15. Kontrolní seznam: Na svém telefonu nebo počítači zjisti a zapiš (bez hesel!), zda máš: zámek obrazovky s PINem nebo biometrií; automatické aktualizace systému a aplikací; antivir nebo vestavěnou ochranu; správce hesel a různá hesla; dvoufaktorové ověření u e-mailu; zálohu dat (kam, jak často); šifrování zařízení. U každé položky uveď stav a co jsi změnil. ★☆☆
16. Co program vypíše? Pravidla vyžadují aspoň 12 znaků, malé a velké písmeno a číslici. Je dlouhé frázové heslo bez číslic opravdu slabší než „Kolo2024Kolo“? Co by měla kontrola hesla ověřovat lépe? ★★☆☆

```
def splnuje_pravidla(heslo):
    male = velke = cislice = False
    for znak in heslo:
        if znak.islower():
            male = True
        elif znak.isupper():
            velke = True
        elif znak.isdigit():
            cislice = True
    return len(heslo) >= 12 and male and velke and cislice
for h in ("Kolo2024", "Kolo2024Kolo", "kolo slon hrnek modra"):
    print(h, splnuje_pravidla(h))
```

C. Problémy a propojení

17. Ransomware ve škole zašifroval počítače i zálohu na síťovém disku, který byl trvale připojen. Navrhni lepší zálohovací plán. Záloha 200 GB dat do cloudu jde rychlostí 50 Mbit/s – jak dlouho trvá první úplná záloha (H37)? ★★☆☆
18. Dřív se doporučovalo měnit heslo každé 3 měsíce. Proč takové pravidlo často bezpečnost snižuje? Co dnes doporučují odborníci (např. americký standard NIST SP 800-63B) a kdy heslo měnit je nutné? ★★☆☆
19. Technologie se mění: Útočník dnes zvládne 10^{10} pokusů/s. Kolik hesel vyzkouší za rok? Jak dlouhé náhodné heslo z malých písmen, resp. z 95 znaků, nevyzkouší celé ani za rok? Kdyby se rychlost útočníků každých 5 let zdesetinásobila, o kolik znaků je třeba heslo prodlužovat? ★★☆☆
20. Služba neukládá hesla, ale jejich otisk (hash). Co program vypíše? Proč server z otisku heslo nezjistí, ale útočník s uniklými otisky přesto může hesla hádat rychlostí 10^{10} /s? Proč by stejné otisky prozradily, že dva uživatelé mají stejné heslo, a jak tomu brání „sůl“? ★★☆☆

```
import hashlib
for heslo in ("kocka123", "kocka123", "kocka124"):
    otisk = hashlib.sha256(heslo.encode()).hexdigest()
    print(heslo, otisk[:16])
```

Hotové úlohy k procvičení na internetu

- **NÚKIB – Dávej kyber: Hesla a přihlašování** – bezpečná a frázová hesla, správce hesel, dvoufaktorové ověřování, úniky údajů
<https://osveta.nukib.gov.cz/mod/page/view.php?id=4269>
- **NÚKIB – Dávej kyber: Sociální inženýrství** – phishing, vishing, baiting a jak je poznat
<https://osveta.nukib.gov.cz/mod/page/view.php?id=4275>
- **NÚKIB – Dávej kyber: Škodlivé soubory a odkazy** – maskování škodlivých souborů, makra, ransomware
<https://osveta.nukib.gov.cz/mod/page/view.php?id=4281>

- **NÚKIB – Dávej kyber: Ochrana zařízení** – aktualizace, antivir, firewall a zálohování

<https://osveta.nukib.gov.cz/mod/page/view.php?id=4284>

★ základní · ★★ střední · ★★★ náročnější. Vyber si, které úlohy spočítáš; řešení ukládej do svého portfolia.

Výsledky ke kontrole

1. a) trojský kůň; b) ransomware; c) phishing (přes SMS = smishing); d) vishing; e) červ; f) credential stuffing; g) virus; h) spyware (keylogger)
2. 10^4 ; 10^6 ; $26^6 = 308\,915\,776$; $36^6 = 2\,176\,782\,336$
3. znám: heslo, PIN, kontrolní otázka; mám: kód z aplikace (telefon), bezpečnostní klíč; jsem: otisk, obličej; heslo + kontrolní otázka není dvoufaktorové – oba faktory jsou stejného typu (znám)
4. naléhavost a hrozba (24 h, zablokování); obecné oslovení; skutečná doména je overeni-uctu.example, ne banka; žádost o heslo i kód z SMS (banka nikdy nechce); odkaz místo pokynu jít do aplikace; správná reakce: na odkaz neklikat, ověřit v aplikaci nebo na známém čísle banky, zprávu nahlásit
5. ne: jen 2 kopie a obě na stejném místě (ztráta nebo krádež zničí obě); přidat třetí kopii mimo – cloud nebo externí disk doma, flashku nosit jinde a zašifrovat; aspoň jedna kopie odpojená (ransomware)
6. $95^{11} \div 5,7 \cdot 10^{21}$ (72 bitů) $\times 7\,776^4 \div 3,7 \cdot 10^{15}$ (52 bitů); první je ale slovo se známými záměnami (o $\rightarrow$ 0, a $\rightarrow$ 4) – slovníkový útok zkouší slova s těmito úpravami, skutečná síla je mnohem menší; náhodně losovaná slova mají plných 52 bitů, 6 slov asi 78 bitů
7. záplata prozradí, kde je chyba – útočníci ji rychle zneužijí u všech, kdo neaktualizovali; zero-day je zranitelnost, kterou útočník zneužívá dřív, než existuje oprava (proti ní chrání spíš antivir, zálohy a opatrnost)
8. (10000, 13.3); (208827064576, 37.6); (540360087662636962890625, 78.8) – počet možných hesel $N = k^n$ a síla v bitech $\log_2 N$
9. $26^8 \div 2,1 \cdot 10^{11} \rightarrow 21$ s; $62^8 \div 2,2 \cdot 10^{14} \rightarrow 6$ h; $62^{12} \div 3,2 \cdot 10^{21} \rightarrow$ asi 10 000 let; $26^{16} \div 4,4 \cdot 10^{22} \rightarrow$ asi 140 000 let
10. online $\frac{10^4}{20} = 500$ h $\div$ 21 dní; offline 10^{-6} s; nebezpečné jsou hlavně úniky databází – heslo uniklé z jedné služby útočník hned zkouší jinde, proto pro každou službu jiné heslo
11. $\log_2 7\,776 \div 12,9$ bitu na slovo; $7\,776^6 \div 2,2 \cdot 10^{23}$ nestačí, $7\,776^7 \div 1,7 \cdot 10^{27}$ ano $\rightarrow$ 7 slov; se slovníkem 50 000 slov stačí 6 slov ($50\,000^5 \div 3,1 \cdot 10^{23}$ ještě ne, $50\,000^6 \div 1,6 \cdot 10^{28}$)
12. $P = \frac{3}{10^4} = 0,03\%$; lidé volí PINy jako 1234, 0000, 1111 nebo rok narození – útočník zkouší nejčastější, proto PIN nevolit podle data ani vzoru
13. chybí mu druhý faktor (telefon); obcházení: falešná stránka, která si vyžádá i kód a hned ho použije; zaplavení žádostmi o schválení, dokud je uživatel omylem nepotvrdí; telefonát „z banky“ s prosbou o kód; obrana: kód zadávat jen na webu, na který jdu sám, neschvalovat nečekané žádosti, kód nikomu nediktovat; odolá bezpečnostní klíč nebo přístupový klíč (passkey) vázaný na skutečnou doménu
14. autorita (IT oddělení), naléhavost (hned), strach (smazané portfolio); reakce: heslo nesdělít nikomu, konverzaci ukončit, ověřit přes známý kontakt (správce IT, učitel) a pokus nahlásit
15. tabulka 7 položek se stavem (ano/ne) a provedenou změnou, např. „zapnul jsem dvoufaktorové ověření u e-mailu, nastavil automatickou zálohu fotek“; žádná hesla ani kódy v odevzdané práci
16. Kolo2024 False (krátké); Kolo2024Kolo True; kolo slon hrnek modra False – přitom 4 náhodná slova jsou výrazně silnější než předvídatelné Kolo2024Kolo; lepší kontrola: délka a porovnání se seznamem uniklých a běžných hesel místo pravidel o typech znaků
17. plán 3-2-1: pravidelná záloha, aspoň jedna kopie odpojená nebo neměnná (offline disk, cloud s historií verzí), zkouška obnovy; čas: $200\text{ GB} = 1,6 \cdot 10^{12}$ bitů, $\frac{1,6 \cdot 10^{12}}{5 \cdot 10^7} = 32\,000\text{ s} \div 8,9\text{ h}$ – další zálohy jen změny (přírůstkově)
18. lidé heslo mění předvídatelně (Jaro2025! $\rightarrow$ Leto2025!) nebo si ho zapisují; doporučení: dlouhé, jedinečné heslo (správce hesel), vícefaktorové ověření, kontrola proti seznamům uniklých hesel, pravidelné vynucené změny ne; měnit hned při podezření na únik nebo prozrazení
19. za rok $\div 3,2 \cdot 10^{17}$ pokusů; $26^n > 3,2 \cdot 10^{17} \Rightarrow n \geq 13$ malých písmen; $95^n \Rightarrow n \geq 9$ znaků; $10\times$ rychlejší útok vyrovná $\log_{26} 10 \div 0,7$ malého písmene, resp. $\log_{95} 10 \div 0,5$ znaku – stačí asi 1 znak navíc za 5 let; proto s rezervou 12–16 znaků
20. kocka123 34c60a03b0d70deb (dvakrát stejně), kocka124 eb8c3f6441468bce (úplně jiný otisk); otisk nejde „obrátit“, ale útočník zahashuje své odhady a porovná je (offline útok); stejné heslo = stejný otisk; sůl = náhodný řetězec přidávaný ke každému heslu před hashováním $\rightarrow$ stejná hesla mají různé otisky a útočník musí hádat každé zvlášť

Úloha 18

1. Vynucená pravidelná změna vede k předvídatelným úpravám (Jaro2025! → Leto2025!) nebo k zapisování hesel – útočník, který zná staré heslo, nové snadno odhadne.
2. Doporučení NIST SP 800-63B: dlouhé a jedinečné heslo (ideálně ve správci hesel) a vícefaktorové ověření.
3. Nová hesla kontrolovat proti seznamům uniklých a běžných hesel; pravidelné vynucené změny bez důvodu nevyžadovat.
4. Heslo změnit hned, když unikla databáze služby, když ho někdo mohl vidět nebo když je podezření na napadení zařízení.

Úloha 19

1. Rok má asi $3,15 \cdot 10^7$ s → za rok $10^{10} \cdot 3,15 \cdot 10^7 \doteq 3,2 \cdot 10^{17}$ pokusů.
2. Malá písmena: $26^{12} \approx 9,5 \cdot 10^{16}$ (málo), $26^{13} \approx 2,5 \cdot 10^{18}$ → aspoň 13 znaků.
3. 95 znaků: $95^8 \approx 6,6 \cdot 10^{15}$ (málo), $95^9 \approx 6,3 \cdot 10^{17}$ → aspoň 9 znaků.
4. $10\times$ rychlejší útok vyrovná heslo delší o $\log_{26} 10 \doteq 0,7$ malého písmene, resp. $\log_{95} 10 \doteq 0,5$ znaku.
5. Stačí tedy zhruba 1 znak navíc každých 5 let; s rezervou se doporučuje 12–16 znaků.

Úloha 20

1. Stejně heslo dá vždy stejný otisk: kocka123 → 34c60a03b0d70deb (dvakrát), kocka124 → eb8c3f6441468bce – malá změna hesla změni otisk úplně.
2. Otisk (hash) nejde „obrátit“ – server heslo nezná, při přihlášení jen porovná otisk zadaného hesla s uloženým.
3. Útočník s uniklými otisky ale může zahashovat své odhady (slovník, všechna krátká hesla) a porovnávat je offline rychlostí asi 10^{10} za sekundu.
4. Stejně otisky v databázi prozradí, že dva uživatelé mají stejné heslo – a jedním uhodnutím útočník získá oba účty.
5. Sůl = náhodný řetězec uložený u každého uživatele a přidaný k heslu před hashováním → stejná hesla mají různé otisky a útočník musí hádat každé heslo zvlášť.